MEDVA PULSE PORTAL

Technical & Organizational Proposal

Prepared by: Jimmy Rhoades
Incoming Director of Development
April 8, 2026

HIPAA-First Design

Agenda

Technology Stack Recommendation 1

Team Composition & Hiring Plan 2

Product Roadmap (MVP → V1 → V2) 3

Architecture Overview 4

Budget & Vendor Management 5

Technology Stack

Recommended Stack (All HIPAA BAA-eligible)

Layer	Choice	Key Reason
Frontend	Next.js 15 + TypeScript + Tailwind + shadcn/ui	Fast dashboards, huge offshore React talent pool
Backend	NestJS (TypeScript) on Fargate	Full TS parity, built-in RBAC guards, modular monolith
Database	Aurora Serverless v2 (PostgreSQL) + RLS	Tenant isolation at DB level, auto-scales to zero
Auth	AWS Cognito + NestJS Guards	MFA, SSO, HIPAA-eligible. Don't reinvent with 5 people.
AI	AWS Bedrock (Claude) + OpenSearch Serverless	Best RAG grounding + instruction-following, HIPAA BAA
Infra	VPC + Fargate + S3 + CloudFront + WAF + KMS	Private subnets only, Fargate over EKS (no cluster tax)
CI/CD	GitHub Actions + Terraform + Docker	IaC everything, build/test/deploy on every PR merge

Internal tooling: GitHub, Linear, Figma, Notion, Slack, Claude Code (~$370/mo)

HIPAA/SOC 2 Compliance

Compliance is a foundation, not a feature

BAA Coverage: Every AWS service on the HIPAA BAA list. Non-BAA for PHI = violation.

Encryption: At rest (KMS, AES-256) and in transit (TLS 1.2+). No exceptions.

Network: VPC with private subnets only. Zero public DB access. WAF + GuardDuty.

Access: Zero developer production access. All changes through application layer with RBAC.

Audit: CloudTrail + custom audit tables for all data access. Immutable logs in S3.

Backup: Daily snapshots, 30-day retention. Multi-AZ. S3 cross-region replication.

Experience: Led SOC 2/HITRUST certification at ilumed. Compliance baked in from Day 1 costs a fraction of retrofitting later.

Architecture enforces compliance at the infrastructure level, not just in application code.

Team Composition

4 Hires + Me (Employee #1, writing 60-70% of foundational code)

Priority	Role	Location	Salary Range	Start
1	DevOps & Security Engineer	US-based	$155K - $175K	Week 1
2	Lead Backend Engineer	Offshore	$40K - $55K	Week 1-2
3	Full-Stack Engineer	Offshore	$35K - $50K	Week 2-3
4	UI/UX Engineer	Offshore	$25K - $40K	Month 2-3

Critical first hire: US DevOps & Security (HIPAA foundation must be rock-solid from Day 1)

Team Evolution

MVP: Me (60-70% backend) + US DevOps + Lead Backend

V1 (AI): I shift to Bedrock/RAG. Add contract AI/ML engineer. Lead Backend steps up.

Later: Offshore team runs autonomously on features within established patterns

Interview Process by Role

Role	Key Evaluation	Process
DevOps & Security (US)	HIPAA infra design, IaC	Infra scenario + Terraform take-home + system-design with me + John
Lead Backend (Offshore)	Tenant isolation, RBAC	Live pair-programming on tenant-isolated endpoint + English assessment
Full-Stack (Offshore)	React + API integration	Live coding + code review exercise (find issues in a PR) + portfolio
UI/UX (Offshore)	Figma-to-code, design system	Live dashboard build from Figma + code review + portfolio

Offshore experience: 50+ devs across US/Ukraine/Central America (Cognizant). Built teams from zero at Red Spot and MedQuest. Async-first, 2-3 hr daily overlap, same standards.

Product Roadmap

MVP → V1 → V2

MVP

10 weeks

AWS infra + CI/CD via Terraform
Cognito auth + RBAC (5 roles)
Portal landing (Client | VA | Corp)
Client dashboard: KPIs, Cost Efficiency
VA portal: profile, schedule, alerts
Corporate: accounts, revenue, risk alerts
Secure messaging (E2E encrypted)
→ Pilot launch: 10-20% of clients

V1

+14 weeks (~6 mo)

Client KB upload + auto-indexing
Medva Frontline AI (Claude RAG)
Chat history + source citations
AI Extensions (Open Evidence, etc.)
Medva Academy (training modules)
Stripe billing (CC + ACH)
VA pay stubs
→ Full client rollout + new revenue

V2

Months 9-14

Matching/assignment engine
Predictive analytics (client health)
EHR integrations (Epic, Athena)
React Native mobile for VAs
Self-service client onboarding
API platform for enterprise
→ Scale & expand

Success Criteria

10-20% client adoption
<2s dashboard load
Zero cross-tenant incidents
Weekly active pilot usage

Migration

Phased migration with feature flags
Dual-run validation before cutover
Existing portal operates in parallel

Integration

Dedicated module (REST/webhooks)
Background jobs + retry queues
External failures isolated from core

QA

Automated tests (unit + API + E2E)
Weekly demo validation

Technical Risks & Mitigations

Phase	Risk	Mitigation
MVP	Data isolation / HIPAA breach	organization_id on every table + RLS + automated security scans in CI + external pen-test
MVP	Data migration delays	Start analysis Week 1, build scripts in parallel, shadow mode before cutover
MVP	Scope creep	Lock scope with John upfront. Weekly demos. Say no to anything outside pilot.
V1	AI cross-tenant leakage	Per-client OpenSearch namespaces + mandatory org_id filter at infra level + nightly automated tests
V1	AI hallucination / quality	RAG grounds responses in docs. Confidence scoring. Low-confidence flagged for human review.
V1	AI cost overrun	Per-client usage quotas, prompt caching, cost-efficient model tier first
Both	Offshore ramp-up	US DevOps first as insurance. Async-first: specs, Loom walkthroughs, 2-3 hr daily overlap.

Architecture Overview

Clients | Virtual Assistants | MEDVA Staff

▼

AWS WAF → Cognito Auth (MFA + SSO + RBAC) → Next.js 15 Frontend

▼

NestJS API (Fargate) | RBAC Guards | Tenant Context Middleware

▼

Aurora Serverless v2
PostgreSQL + RLS

S3 (KMS Encrypted)
Client KB Documents

Bedrock (Claude)
+ OpenSearch Vectors

CloudWatch | GuardDuty | CloudTrail | KMS | Secrets Manager | Stripe

All traffic in private subnets. All data encrypted at rest + in transit. Zero public DB access.

Auth & Multi-Tenancy

Authentication & RBAC

Cognito: MFA (required for PHI), SSO (SAML/OIDC), user pools

JWT: 15-min access tokens, 7-day rotating refresh

5 roles: Client Admin, Client User, VA, MEDVA Corporate, MEDVA Admin

Defense in depth: App-level RBAC + DB-level RLS (two independent layers)

Multi-Tenancy Strategy

Shared DB, logical isolation via organization_id + PostgreSQL RLS

RLS enforced at DB level -- even buggy app code can't leak tenant data

Why not separate DBs? 1,000+ clients = unmanageable migrations + no cross-tenant analytics

Even if application logic has a bug, the database won't return another tenant's data.

AI KB Isolation

How We Guarantee No Cross-Tenant Leakage (Highest HIPAA Risk Area)

1. Client uploads document → S3 under tenant_id/ prefix, encrypted via KMS
2. Async pipeline (SQS + Lambda): parse, chunk, embed
3. Embeddings stored in OpenSearch with org_id metadata tag
4. VA asks question → OpenSearch query with mandatory org_id filter (infrastructure-level)
5. Retrieved chunks + question sent to Claude via Bedrock (stateless -- no data persists)
6. Response returned with source citations from that client's KB only
7. Nightly automated cross-tenant tests -- must return zero results or pipeline stops

HIPAA-safe by design. Bedrock is stateless. Isolation is enforced at infrastructure level, not application level.

Budget & Vendor Management

Monthly Cloud Infrastructure (10-20% adoption)

Phase	Est. Monthly Cost	Key Drivers
MVP	$800 - $1,200	Aurora Serverless (scales to zero), Fargate, S3, CloudFront
V1	$2,200 - $2,900	+ Bedrock inference ($500-$1,200 variable), OpenSearch, Lambda
Full Adoption	$8K - $12K	Linear scaling with Fargate auto-scale + Bedrock usage

Annual Team Cost (4 hires): ~$330K

US DevOps ~$195K | Lead Backend ~$52K | Full-Stack ~$46K | UI/UX ~$37K

Software Licensing: ~$400/mo

GitHub, Linear, Figma, Notion, Slack, Claude Code, 1Password, Sentry, PagerDuty. Stripe fees pass-through.

Cost Optimization

Aurora Serverless: auto-scales to near-zero off-hours

Savings Plans: 1-year compute after MVP (~35% savings)

Fargate Spot: batch processing at up to 70% discount

Bedrock: per-client quotas, prompt caching, cost-efficient tier first

Monthly FinOps reviews with budget alerts at 80% and 100%

Build vs. Buy

Capability	Decision	Why
Auth	BUY (Cognito)	Mature + BAA-covered. Don't reinvent with 5 people.
Messaging	BUILD	Core differentiator + E2E encryption. SendBird scales poorly at 5K+ VAs.
Medva Frontline AI	BUILD RAG + Claude via Bedrock	We own the pipeline + isolation. Strongest model for grounding responses in retrieved docs.
Medva Academy	BUILD (V1)	Mock-up shows deep portal integration. Thinkific can't deliver this.
AI Extensions	BUILD framework	Pluggable architecture. Third-party vendors provide AI via API.
IT Ticketing	INTEGRATE	Not a differentiator. Zendesk/Freshdesk via API.
Billing	BUY (Stripe)	PCI compliance out of the box. Never build payment processing.
CRM	INTEGRATE (HubSpot)	Already in use. Bi-directional sync, don't replace.

Build if it's a core differentiator or touches PHI. Buy if it's commodity. Integrate if MEDVA already uses it.

Key Assumptions

Building from scratch (no legacy dependencies to inherit)

AWS account with active BAA available or will be provisioned

API/data access to current systems available for migration

Offshore hiring leverages MEDVA's existing Philippines HR infrastructure

10-20% adoption (100-200 clients) for cost modeling

Thank You

Happy to go deeper on any section in the walkthrough.

Jimmy Rhoades

jimmyrhoades1@gmail.com | 770.331.7637